



ISC 互联网安全大会



360 互联网安全中心

威胁情报中的发展和创新

韩志立 360威胁情报中心

2018 ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China
(原中国互联网安全大会)

目录

- 一、现状和思考
- 二、创新与发展
- 三、情报能力发展模型

战术情报 MRTI

- C&C：出局流量检测
- IP情报：入局流量检测
- 文件信誉：主机&内容检测

作战情报

- 威胁分析平台：报警分析、定性分析、关联分析
- 事件/漏洞预警通告

战略情报

- 针对性攻击对手的
- 攻击目的
 - 危害/范围
 - 怎么攻/怎么防

- 安全设备集成，进行检测和防御
 - NGFW/IPS
 - 沙箱
 - 高级威胁检测设备
 - 终端安全
- 大数据平台集成，进行检测
 - SIEM (Splunk、Qradar)
 - SOC
 - ES

- Target 为数据泄露事件付出的代价为 2.02亿美元；
- Target 表现出了对安全的高度重视，雄心勃勃组建了300+员工的安全团队；
- 现网FireEye设备检测到 exfiltration malware 的安装过程并进行多次告警；
- Target 的安全人员事先关闭了 FireEye 设备的在线阻断功能；
- 他们还忽略了 Symantec 终端防护软件同时被触发的告警

Missed Alarms and 40 Million Stolen Credit Card Numbers: How Target Blew It

Target ignored its own alarms—and turned its customers into victims

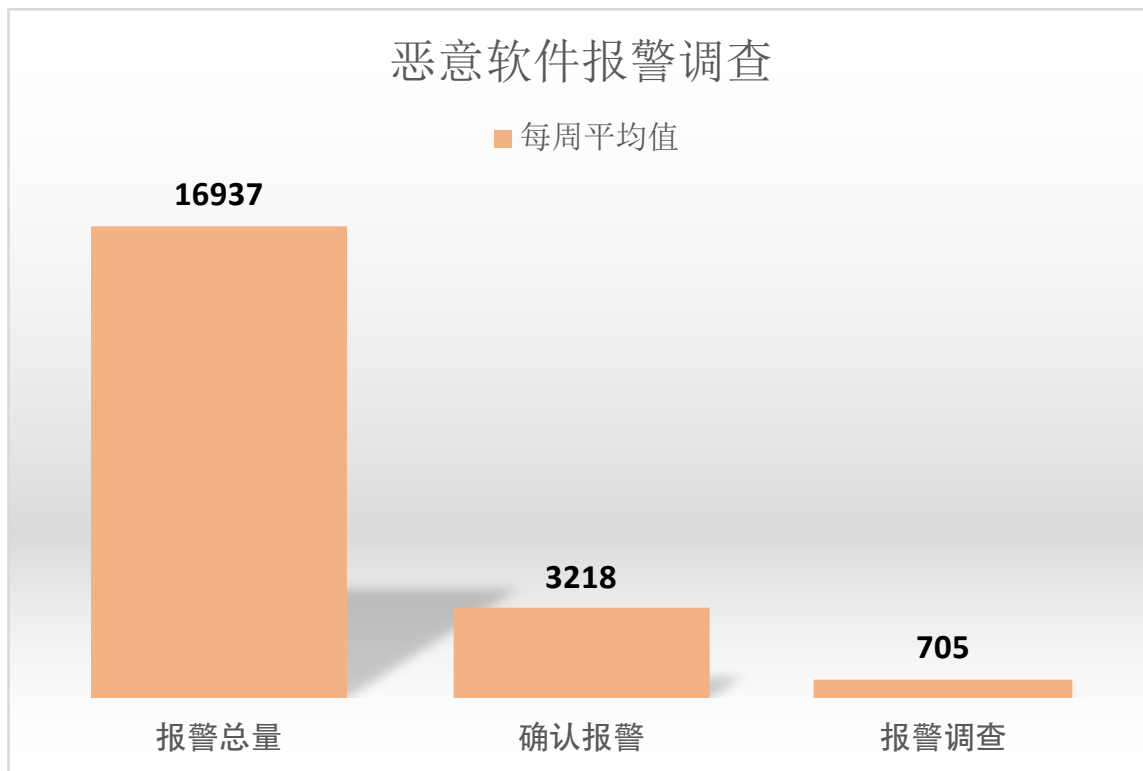
By Michael Riley, Ben Elgin, Dune Lawrence, and Carol Matlack

2014年3月17日 GMT+8 下午10:31



参考：《从 Target 事件看安全运营的困境》

不是特例，而是普遍现象

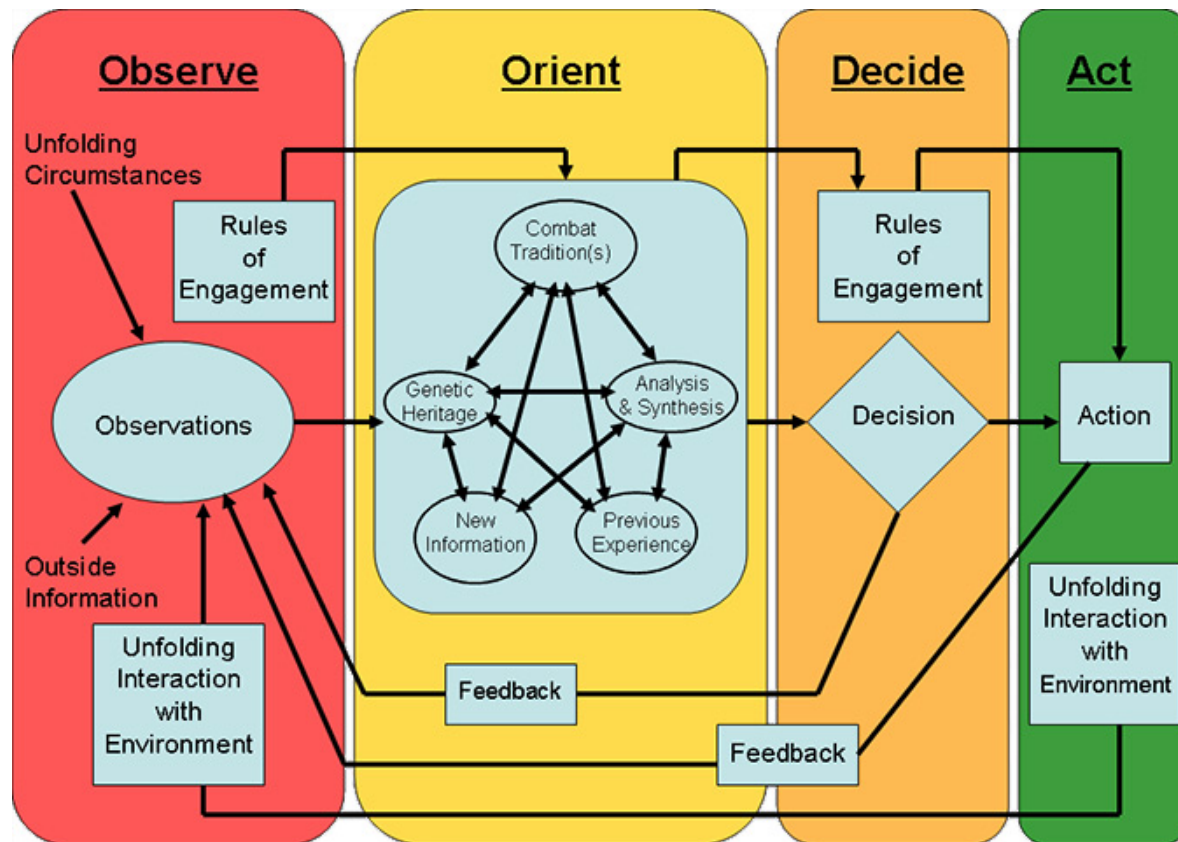


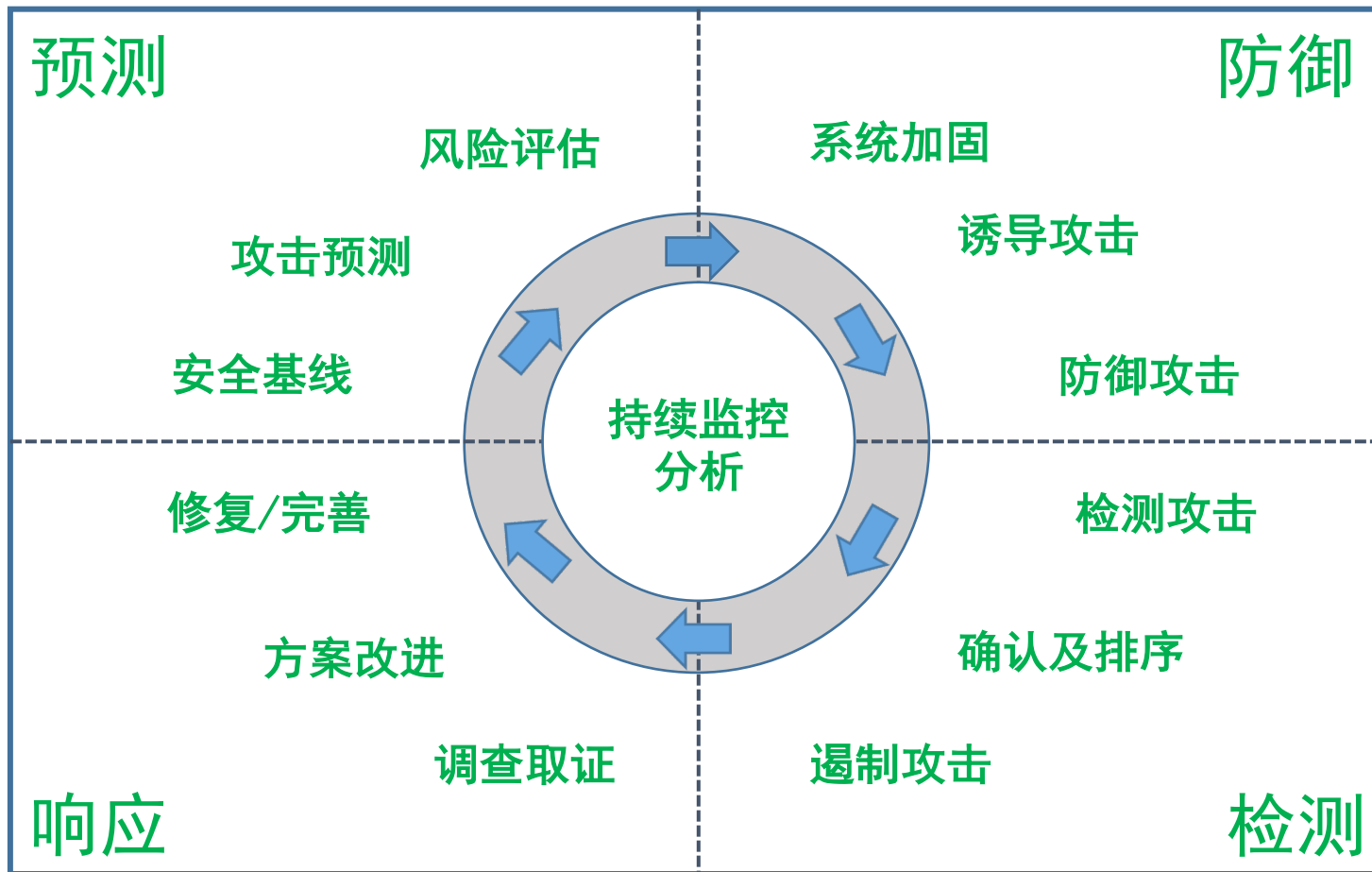
组织每周大约接收17000条报警，
其中19%是可靠的，而其中4%会被
调查处理

——Ponemon 《The Cost of
Malware Containment 》

问题的剖析

- 发现安全事件后，首先需要进行定性分析，据此进行决策，才能进行实质的活动（OODA）；
- 缺乏有经验的分析人员；
- 分析人员缺乏必要的工具，造成效率低下，甚至无法进行特定的分析工作；





目录

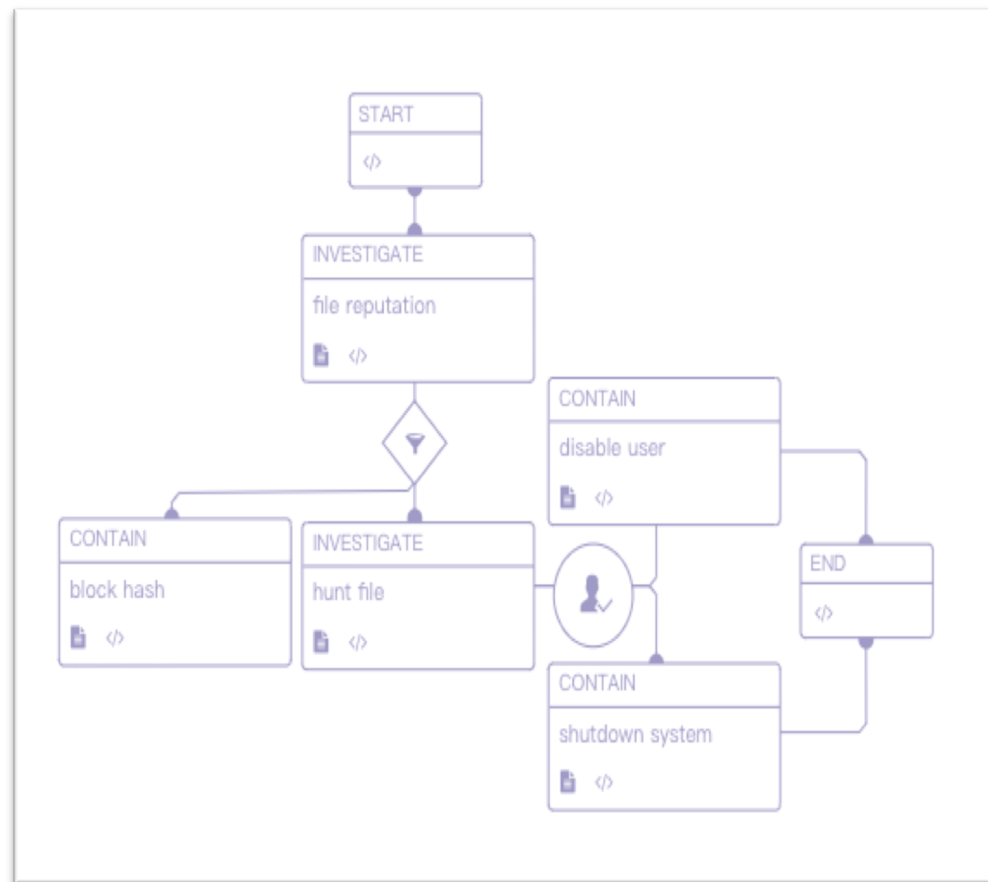
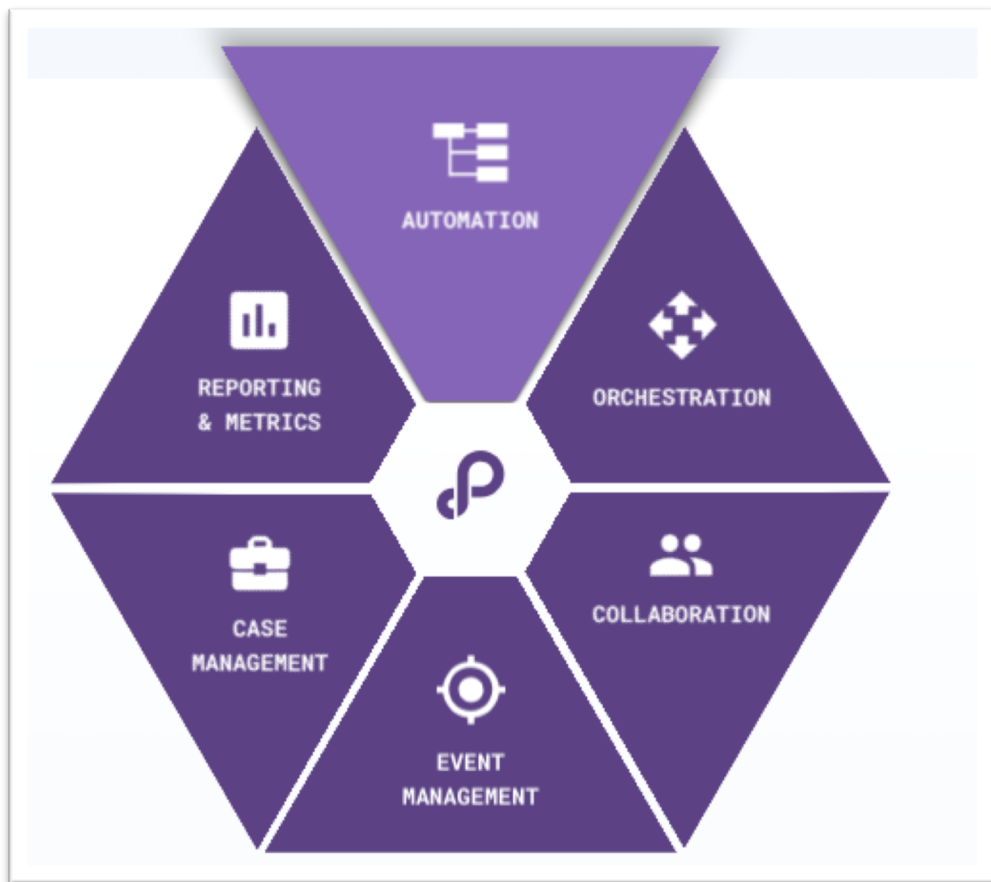
一、现状和思考

二、创新与发展

- SOAR
- 可视化关联分析
- 本地情报能力

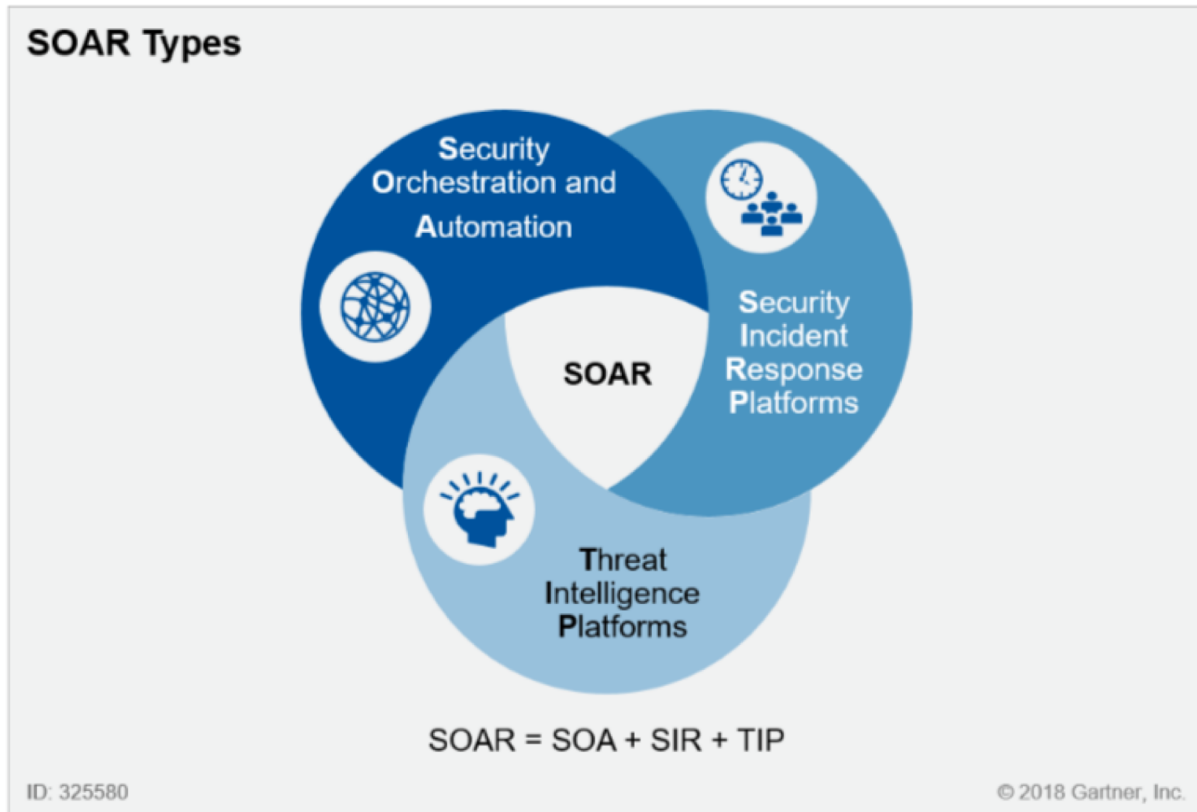
三、情报能力发展模型

SOAR 安全编排、自动化和响应

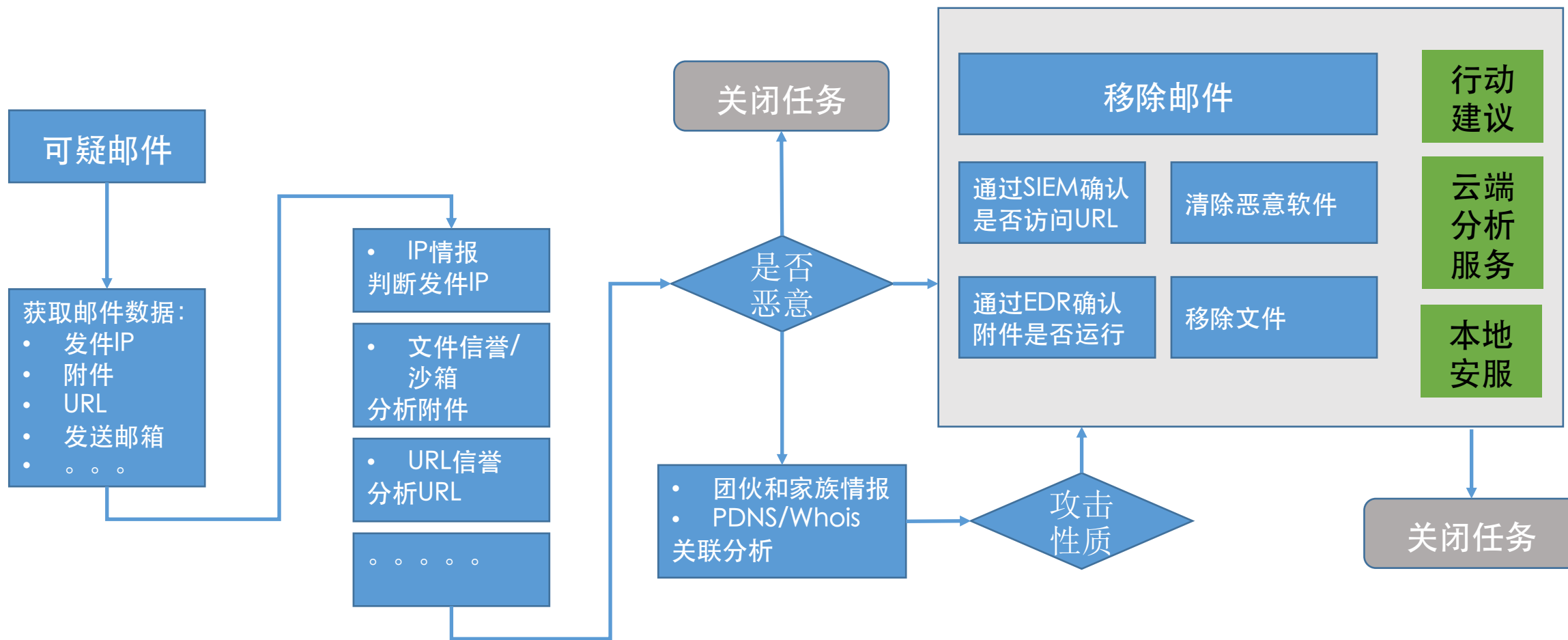


SOAR类产品的灵魂：

- 威胁情报；
- 事件响应经验；



示例：



解决的问题：

- 基于场景，完整的情报能力；——数据能力
- 内置标准化的分析方法和逻辑；——分析经验
- 提供不同类型威胁的标准处理方法；——响应经验

局限

- 难以替代人做复杂的关联分析；
- 受限于厂商的情报能力和分析、响应经验；

数据

大数据

- 沙箱行为数据
- pDNS数据
- Whois数据
- 攻击团伙/家族档案库

小数据

- CDN
- 动态域名
- GFW
- Sinkhole
- TOP-DNS
- Whois 隐私保护
-

能力要求

经验/方法

- 互联网的整体架构
- 互联网服务的基础知识
- 恶意软件分析的基础知识
- 分析对抗经验
- 结构化分析方法
 - Checklist
 - 时间线
 - 排序
 - 分级
 - 韦恩图
 - Gantt图
 - 矩阵分析
 - 网络分析
 -

可视化关联 DEMO

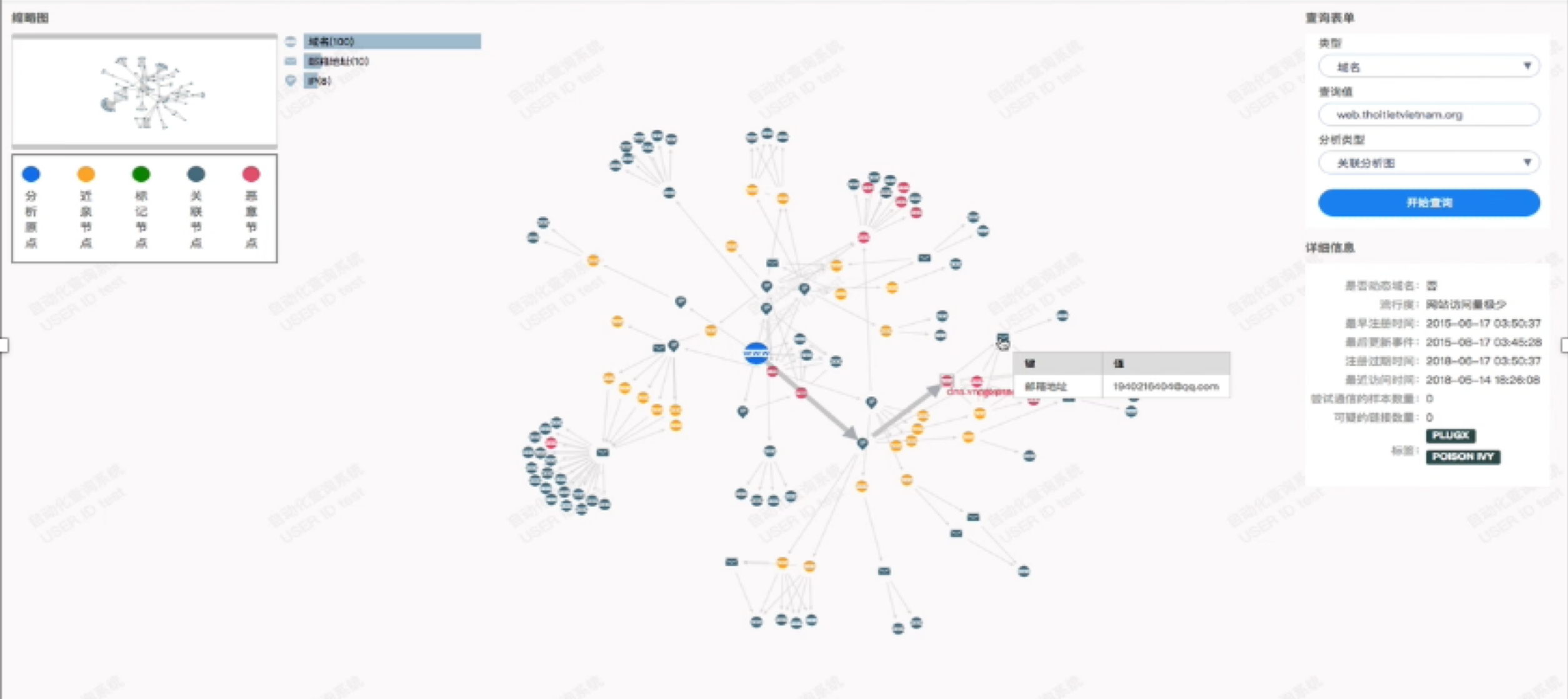


ISC 互联网安全大会

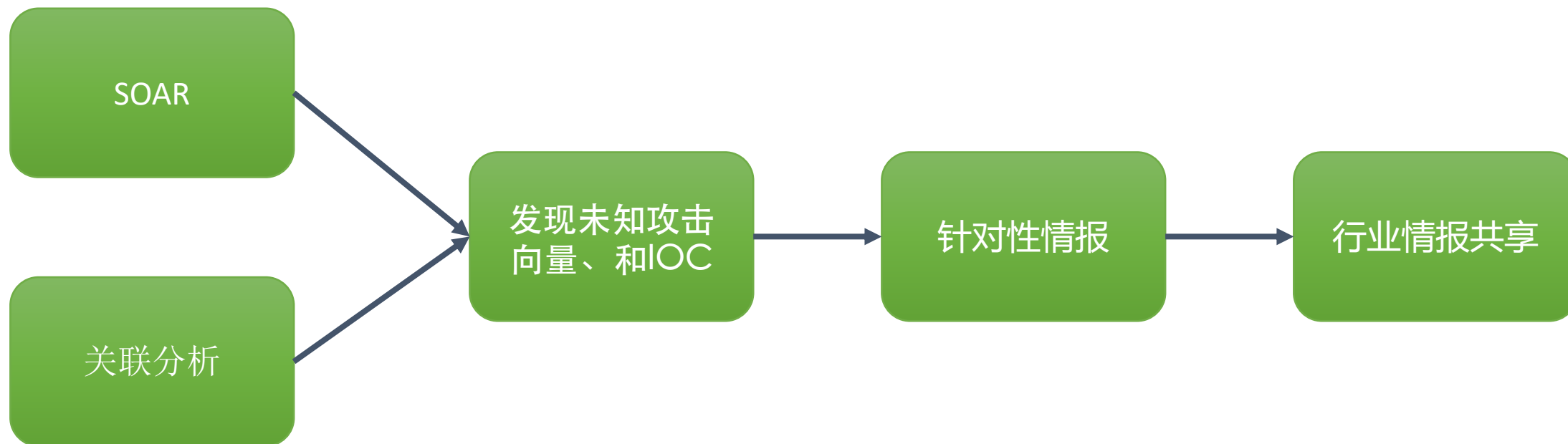


360 互联网安全中心

- 网状布局
- 树状布局
- 横构树状布局
- 引力布局
- 环状布局
- 显示名称
- 放大
- 缩小



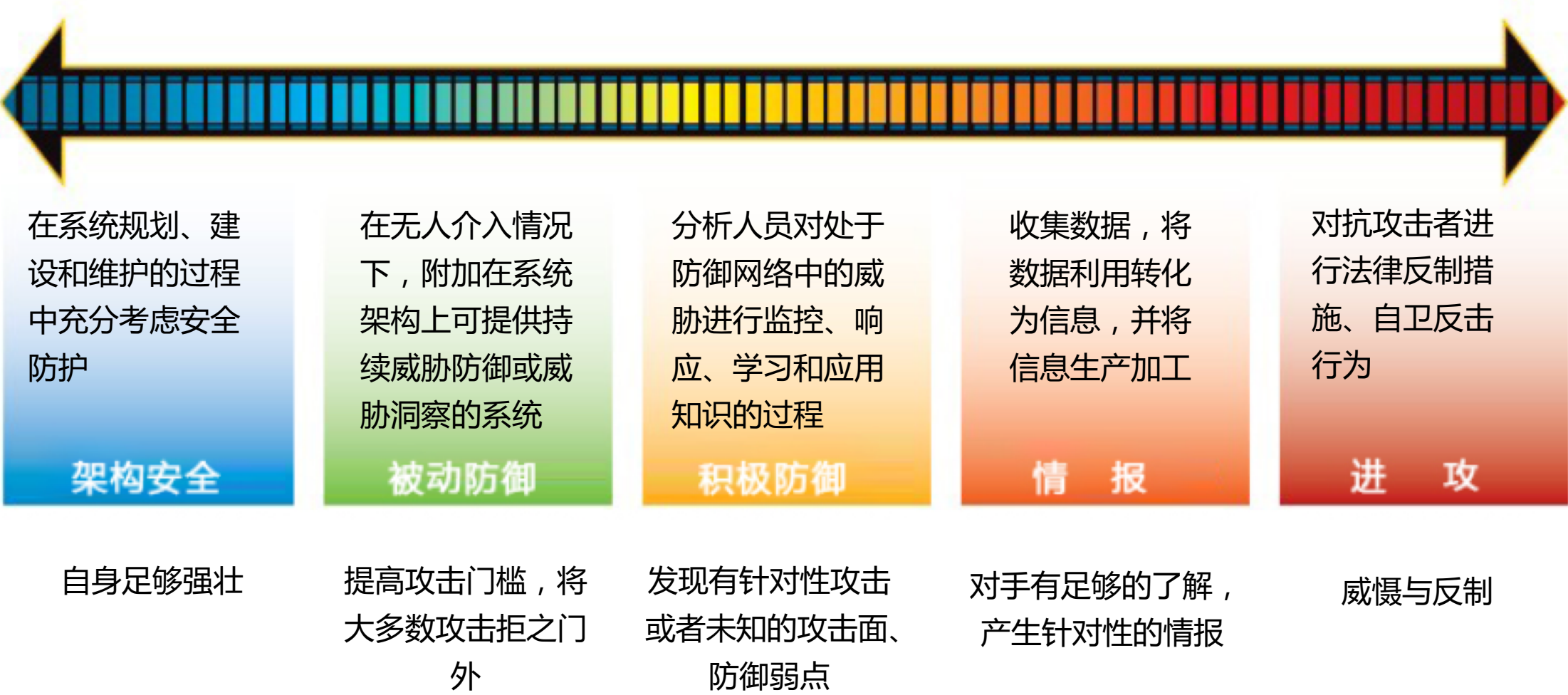
- 利用SOAR和关联分析能力，形成情报生产能力，以此为基础的情报共享会形成客户利益最大化。



- 越有价值的情报共享，越需要右侧的数据来源；
- 广泛事件响应能力是威胁情报共享发展的基础；



安全能力的叠加演进

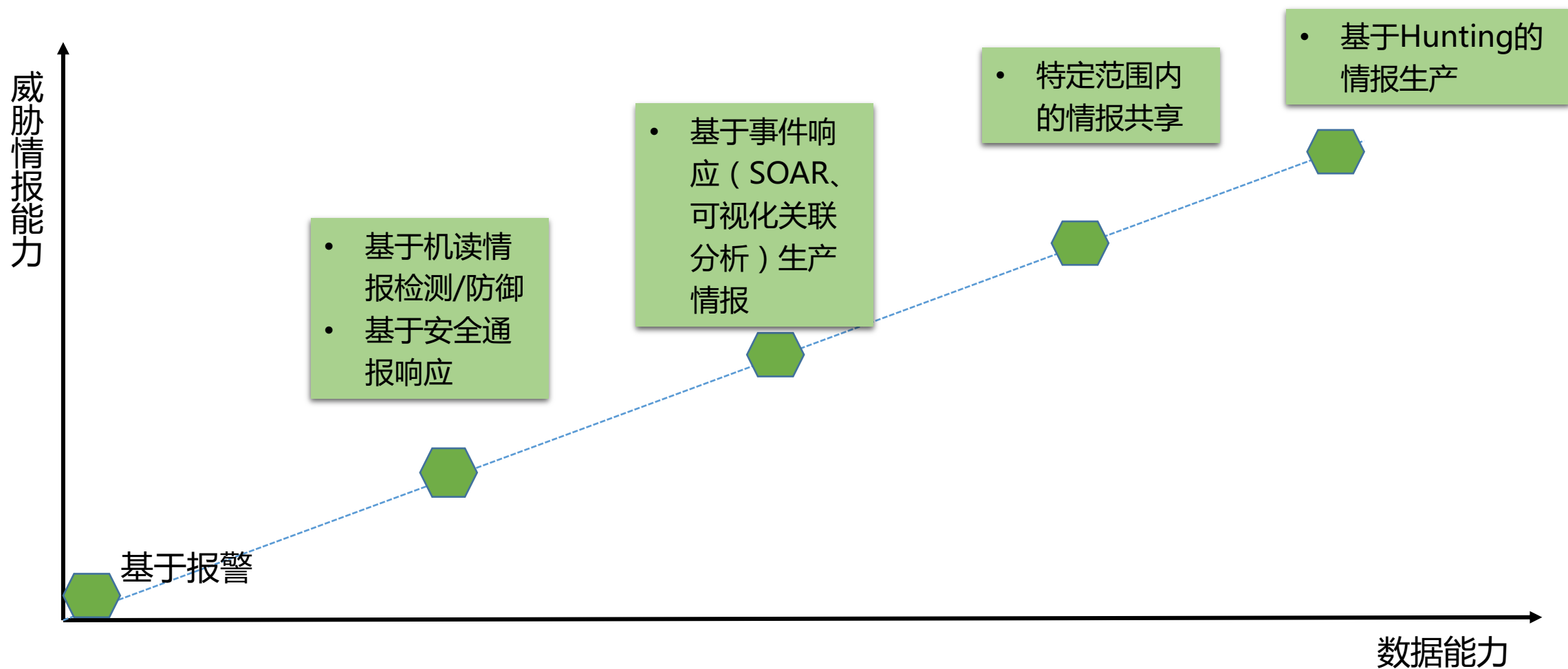


目录

一、现状和思考

二、创新与发展

三、情报能力发展模型



One more thing



愿你的道路漫长，充满奇迹，充满发现。
愿一路之上大家能彼此交流，共同进步。



360威胁情报中心

Ti.360.net



ISC 互联网安全大会



360 互联网安全中心

谢谢！

2018 ISC 互联网安全大会 中国 · 北京
Internet Security Conference 2018 Beijing · China
(原中国互联网安全大会)